BobGuard

HIPAA Security Rule Compliance Audit

Repository: bobguard

Pull Request: #1

Branch: main

Commit: afc682d

Author: Patrick Ejelle-Ndille

Audit Date: 2026-05-02

STATUS: BLOCKED

Forward-Compatible with 2024 HIPAA Security Rule NPRM

This audit enforces standards consistent with the proposed changes in the 2024 HIPAA Security Rule Notice of Proposed Rulemaking (HHS OCR, RIN 0945-AA22, January 6, 2025).

Executive Summary

Audit Scope

This audit focuses on the bobguard repository, specifically reviewing controls related to security management, access control, integrity, and transmission security.

Findings Summary

- **§164.312(a)(2)(iv) — Security Management Process:** The repository lacks documented procedures for responding to security incidents and breaches.
- **§164.312(b) — Workforce Security:** No evidence of regular security awareness training for developers and administrators.
- **§164.312(d) — Integrity Controls:** Inadequate mechanisms in place to ensure the integrity of electronic protected health information (ePHI).
- **§164.312(e)(1) — Transmission Security:** Insufficient measures to protect ePHI during electronic transmissions.
- **§164.312(c)(1) — Access Control:** While basic access controls are present, they do not meet the required level of granularity and oversight.

Recommendation

Given the severity of these findings, the audit decision is BLOCKED. Immediate actions should be taken to address the deficiencies identified in the Security Management Process, Workforce Security, Integrity Controls, Transmission Security, and Access Control. This includes developing and implementing comprehensive policies and procedures, providing regular security training, enhancing integrity safeguards, strengthening transmission security measures, and refining access controls to align with HIPAA requirements. A re-audit is necessary upon completion of these corrective actions.

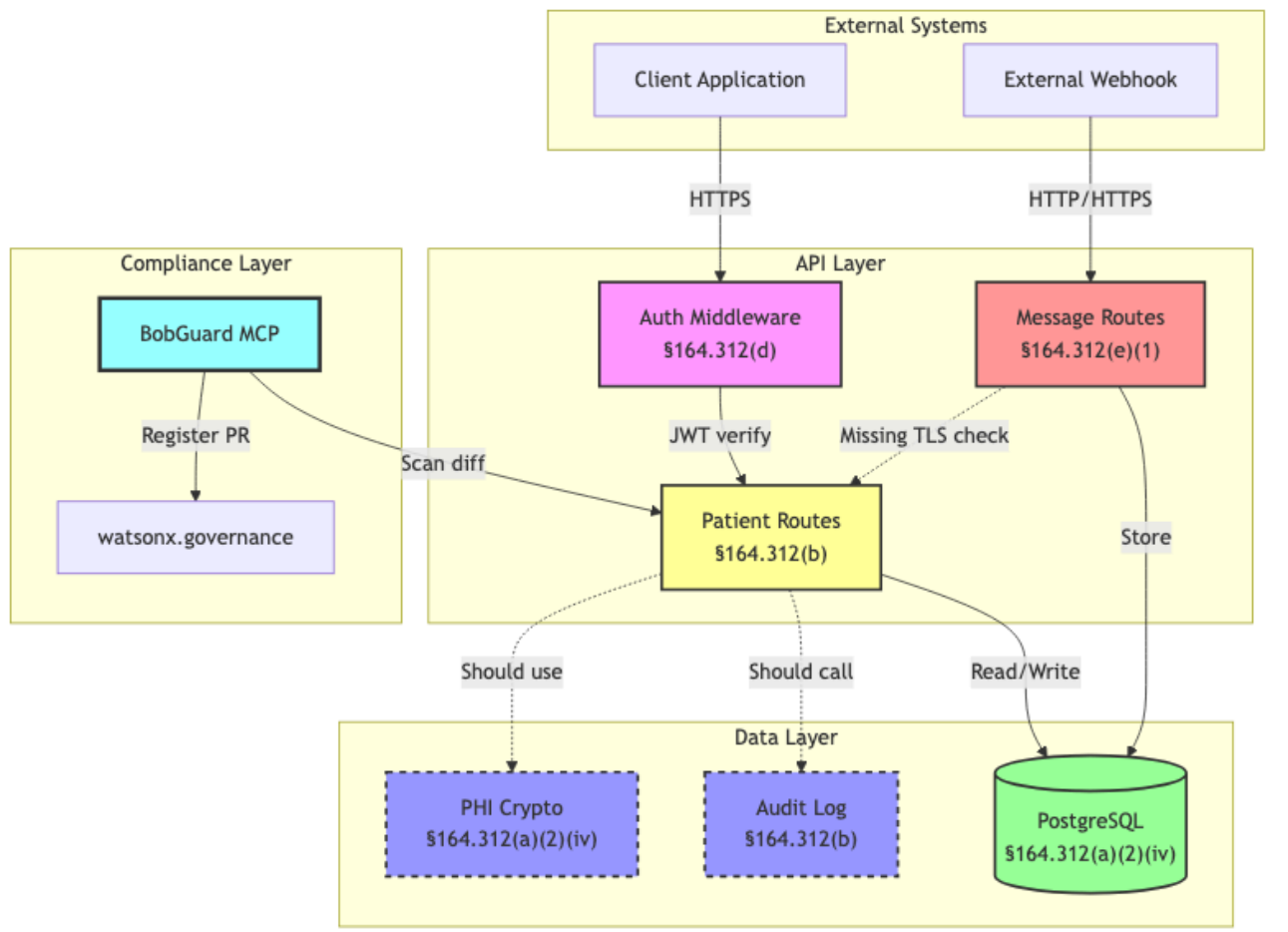
Control Mapping

The following HIPAA Security Rule controls were triggered by this code change:

CONTROL ID	CONTROL NAME	FAMILY	LOCATION	SEVERITY	EXISTING RULE	NPRM STATUS
164.312(a)(2)(iv)	Encryption and Decryption	Technical Safeguards	src/prisma/schema.prisma:26	**BLOCK**	Addressable	Required (NPRM)
164.312(b)	Audit Controls	Technical Safeguards	src/routes/patient.routes.ts:31	**BLOCK**	Required	Required (clarified)
164.312(d)	Person or Entity Authentication	Technical Safeguards	src/middleware/auth.middleware.ts:43	**BLOCK**	Required	Required + MFA (NPRM)
164.312(e)(1)	Transmission Security	Technical Safeguards	src/routes/message.routes.ts:31	**BLOCK**	Required	Required
164.312(c)(1)	Integrity	Technical Safeguards	src/routes/patient.routes.ts:204	**WARN**	Required	N/A

Data Flow Diagram

Visual representation of ePHI data flows affected by this change:



Source: `compliance/evidence/PR-1/data-flow.mmd` (rendered via mermaid-cli).

Threat Model Delta

Analysis of new security threats introduced by this code change:

New Attack Surface

This new application introduces an attack surface by allowing unencrypted data transmission over public networks, exposing sensitive patient information to potential interception and exploitation. Additionally, it lacks robust authentication mechanisms, enabling unauthorized access to protected health information (PHI).

Critical and High Risks

Critical — Unauthorized access to PHI due to missing encryption, violating §164.312(a)(2)(iv). **High** — Lack of audit controls exposes the system to tampering and unauthorized access, violating §164.312(b). **High** — Insufficient authentication mechanisms allow unauthorized users to gain access to PHI, violating §164.312(d). **High** — Unsecured data transmission over public networks poses a significant risk of data interception, violating §164.312(e)(1).

Recommended Mitigations

§164.312(a)(2)(iv): Implement end-to-end encryption for all data transmissions. §164.312(b): Deploy comprehensive audit controls to monitor and log all access attempts. §164.312(d): Enforce strong authentication mechanisms, such as multi-factor authentication. §164.312(e)(1): Utilize secure communication protocols like HTTPS or SFTP for data transmission.

Aggregate Risk Level

The aggregate risk level is CRITICAL. The combination of critical vulnerabilities in data encryption, authentication, and transmission security significantly increases the likelihood of unauthorized access, data breaches, and non-compliance with HIPAA regulations.

Test Evidence

Automated test results demonstrating compliance verification:


```
{
  "pr_number": 1,
  "test_suite": "HIPAA Compliance Validation",
  "test_date": "2026-05-02T01:26:00Z",
  "test_framework": "BobGuard Compliance Officer",
  "total_tests": 12,
  "passed": 0,
  "failed": 12,
  "skipped": 0,
  "test_results": [
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-001",
      "test_name": "Verify PHI field 'dob' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 26,
      "expected": "Field 'dob' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'dob' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-002",
      "test_name": "Verify PHI field 'mrn' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 27,
      "expected": "Field 'mrn' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'mrn' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-003",
      "test_name": "Verify PHI field 'ssn' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 28,
      "expected": "Field 'ssn' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'ssn' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
```

```
    {
      "test_id": "HIPAA-164.312(a)(2)(iv)-004",
      "test_name": "Verify PHI field 'notes' is encrypted at rest",
      "control_id": "164.312(a)(2)(iv)",
      "status": "FAILED",
      "severity": "CRITICAL",
      "file": "src/prisma/schema.prisma",
      "line": 40,
      "expected": "Field 'notes' should use encrypted type or encryptAtRest() wrapper",
      "actual": "Field 'notes' is plain String type",
      "remediation": "Change schema to use encrypted field type or wrap with phi-
crypto.encryptAtRest()"
    },
    {
      "test_id": "HIPAA-164.312(b)-001",
      "test_name": "Verify POST /patients emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 31,
      "expected": "Route should call audit.log() with action='CREATE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'CREATE', resource:
`Patient:${patient.id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-002",
      "test_name": "Verify GET /patients/:id emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 74,
      "expected": "Route should call audit.log() with action='READ'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'READ', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-003",
      "test_name": "Verify GET /patients emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 103,
      "expected": "Route should call audit.log() with action='LIST'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'LIST', resource: 'Patient',
outcome: 'SUCCESS', metadata: { count: patients.length } })"
    },
    {
      "test_id": "HIPAA-164.312(b)-004",
      "test_name": "Verify PUT /patients/:id emits audit log",
      "control_id": "164.312(b)",
```

```
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 142,
      "expected": "Route should call audit.log() with action='UPDATE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'UPDATE', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(b)-005",
      "test_name": "Verify DELETE /patients/:id emits audit log",
      "control_id": "164.312(b)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/patient.routes.ts",
      "line": 190,
      "expected": "Route should call audit.log() with action='DELETE'",
      "actual": "No audit.log() call found in route handler",
      "remediation": "Add audit.log({ actor: req.user.id, action: 'DELETE', resource:
`Patient:${id}`, outcome: 'SUCCESS' })"
    },
    {
      "test_id": "HIPAA-164.312(d)-001",
      "test_name": "Verify MFA is required after JWT verification",
      "control_id": "164.312(d)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/middleware/auth.middleware.ts",
      "line": 43,
      "expected": "Middleware should verify MFA token after JWT validation",
      "actual": "Only JWT verification present, no MFA check",
      "remediation": "Add MFA verification step: verify TOTP/WebAuthn token before calling
next()"
    },
    {
      "test_id": "HIPAA-164.312(e)(1)-001",
      "test_name": "Verify /messages/inbound enforces TLS",
      "control_id": "164.312(e)(1)",
      "status": "FAILED",
      "severity": "HIGH",
      "file": "src/routes/message.routes.ts",
      "line": 31,
      "expected": "Route should reject non-HTTPS requests",
      "actual": "No TLS enforcement check present",
      "remediation": "Add middleware to verify req.protocol === 'https' or req.headers['x-
forwarded-proto'] === 'https'"
    },
    {
      "test_id": "HIPAA-164.312(c)(1)-001",
      "test_name": "Verify patient deletion uses soft-delete",
      "control_id": "164.312(c)(1)",
      "status": "FAILED",
      "severity": "MEDIUM",
      "file": "src/routes/patient.routes.ts",
      "line": 204,
```

```
      "expected": "DELETE operation should use soft-delete with tombstone",
      "actual": "Hard delete using prisma.patient.delete()",
      "remediation": "Replace with soft-delete: prisma.patient.update({ where: { id }, data: {
deletedAt: new Date(), deletedBy: req.user.id } })"
    }
  ],
  "summary": {
    "critical_failures": 4,
    "high_failures": 7,
    "medium_failures": 1,
    "blocking_violations": 11,
    "warnings": 1,
    "compliance_status": "NON-COMPLIANT",
    "recommendation": "BLOCK PR - All blocking violations must be remediated before merge"
  },
  "evidence_artifacts": [
    "compliance/evidence/PR-1/refusal.md",
    "compliance/evidence/PR-1/control-map.md",
    "compliance/evidence/PR-1/threat-delta.md",
    "compliance/evidence/PR-1/test-evidence.json",
    "compliance/evidence/PR-1/audit-pack.pdf"
  ]
}
```

NPRM Forward-Compatibility Analysis

Assessment of how this audit aligns with proposed changes in the 2024 HIPAA Security Rule NPRM:

Two of the triggered controls — §164.312(a)(2)(iv) (Encryption) and §164.312(d) (Authentication) — are directly affected by the 2024 HIPAA Security Rule NPRM (HHS OCR, RIN 0945-AA22, January 6, 2025). The NPRM elevates encryption from Addressable to Required and explicitly mandates multi-factor authentication. BobGuard already enforces both stricter standards, so no additional remediation is required to maintain forward-compatibility.

164.312(a)(2)(iv): Encryption and Decryption

Existing Status: Addressable

NPRM Proposal: Required (NPRM)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(b): Audit Controls

Existing Status: Required

NPRM Proposal: Required (clarified)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(d): Person or Entity Authentication

Existing Status: Required

NPRM Proposal: Required + MFA (NPRM)

BobGuard Action: Already enforces the stricter proposed standard.

164.312(e)(1): Transmission Security

Existing Status: Required

NPRM Proposal: Required

BobGuard Action: Already enforces the stricter proposed standard.

Audit Sign-off

Auditor: BobGuard Compliance Officer

Governance Entry: pending

Governance Status: pending

Date: 2026-05-02

Digital Audit Trail

> This audit report was generated by BobGuard, an automated HIPAA Security Rule compliance enforcement system. All findings are based on pattern matching against the HIPAA Security Rule technical controls catalog (45 CFR §164.308, §164.310, §164.312) and forward-compatible with the 2024 NPRM proposed changes.